

CCCS 454 – Security Incident Response and Recovery

Project - Part 1 – Creating a tabletop scenario

Al Labade, Ayman

1. Sector Selection and Organization

- Sector: Automotive Manufacturing and Supply Chain
- Organization Name: Apex AutoSystems Ltd.

2. Organization Overview

Apex AutoSystems Ltd. Is a leading Tier 1 automotive supplier headquartered in Detroit, Michigan, with manufacturing facilities in Mexico and Germany. The company specializes in the design, development, and manufacturing of advanced **Electronic Control Units (ECUs)** and **Telematics Control Units (TCUs)** for autonomous and electric vehicles. Apex AutoSystems focuses on bridging the gap between traditional automotive hardware and modern software-defined vehicles.

Clients: The primary clients are major Original Equipment Manufacturers (OEMs) such as Ford, General Motors, Toyota and Tesla. These clients rely on Apex for “Just-In-Time” (JIT) delivery of components directly to their assembly lines. A delay of even a few hours from Apex can halt a client’s entire production line, leading to massive financial penalties.

Suppliers: Apex sources microchips and semiconductors from global foundries like TSMC (Taiwan) and Infineon (Germany), as well as raw materials (PCB substrates, connectors) from various suppliers in Southeast Asia.

3. Key Business Processes

Process 1: Just-In-Time (JIT) Manufacturing and Assembly

- **Description:** This process involves the automated assembly of printed circuit boards (PCBs), soldering of components and the initial “flashing” of base firmware onto the ECUs. It is tightly integrated with client inventory systems; when a client like Ford starts building a car, a signal is sent to Apex to manufacture the specific ECU for that VIN
- **Criticality:** This process is the financial backbone of the company. Because of the automotive industry operating on JIT principles, Apex holds very little inventory. If this manufacturing process is interrupted for more than 4 hours, Apex then fails to meet the delivery windows, incurring penalties of up to \$50 000 per minute of OEM clients and risking contract termination.

Process 2: Secure Firmware Over-the-Air (FOTA) Distribution

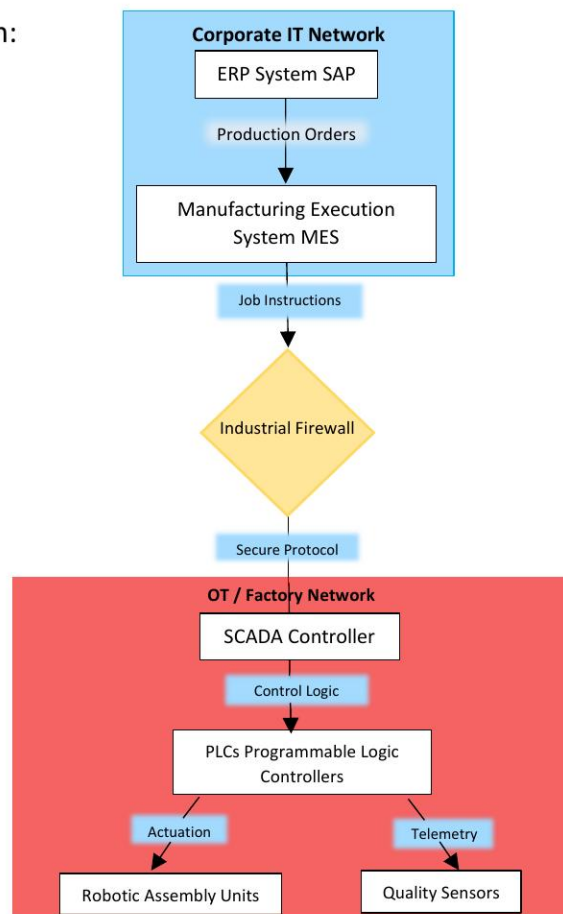
- **Description:** This process allows Apex to push critical software updates, security patches and feature enhancements to millions of its ECUs already installed in vehicles on the road. The process involves code signing (using Hardware Security Modules), encryption, and distribution via a cloud-based content delivery network (CDN).
- **Criticality:** This is a critical safety and compliance process. If a software bug affects vehicle braking or steering (like the ABS modules Apex produces), the FOTA system is the only way to fix it quickly without a physical recall. A compromise of this process could allow attacks to push malicious code to cars, endangering lives

4. System Architectures

Architecture 1: JIT Manufacturing System

- **Description:** The architecture consists of a Corporate IT network (where orders are received via ERP) and a segregated OT (Operational Technology) network where the physical manufacturing happens. A “Demilitarized Zone” (DMZ) with an industrial firewall separates the two. The Manufacturing Execution System (MES) bridges the gap, translating business orders into commands for the SCADA/PLC controllers that drive robotic assembly arms.

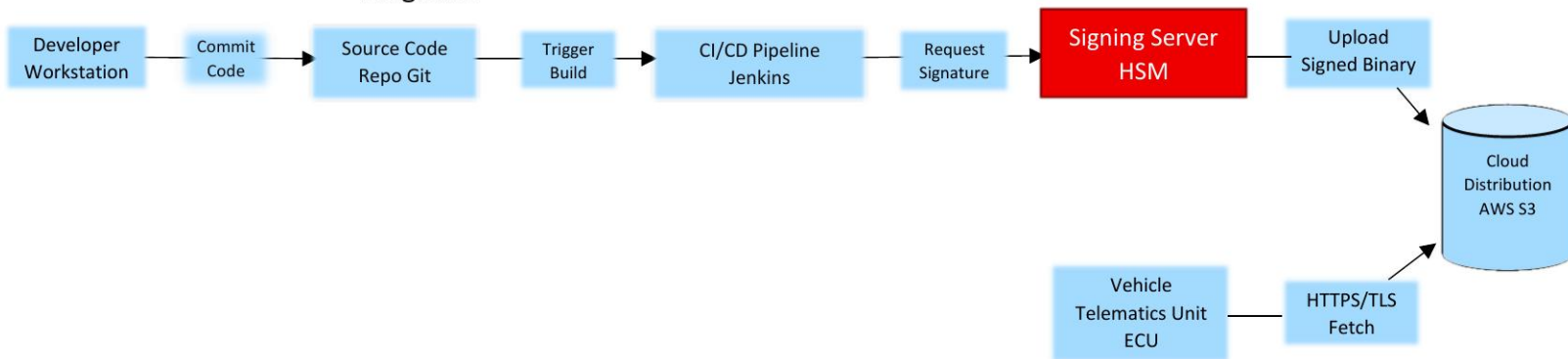
- **Diagram:**



Architecture 2: Secure FOTA Pipeline

- Description: Developers write code on secure workstations which is pushed to a central repository. A CI/CD pipeline automates testing. The critical component is the Signing Server (HSM), which holds the private cryptographic keys used to digitally sign the firmware. Only signed firmware is accepted by the vehicle's ECU. The signed binary is hosted on a Cloud CDN (AWS) for vehicles to download.

- Diagram:



5. Incident Scenario

Scenario: "The Phantom Patch"

Scenario: On a Tuesday morning, the Apex Security Operations Center (SOC) detects an anomaly. A developer's credentials were compromised via a phishing attack, allowing an attacker to pivot laterally into the CI/CD environment. The attacker has deployed Ransomware specifically targeting the Signing Server (HSM) and the Manufacturing Execution System (MES) database.

Simultaneously, the attacker has exfiltrated the "Gold Master" private signing keys. They send a ransom note stating: *"We have encrypted your manufacturing database, halting your production. We have obtained access to all your private signing keys. If you do not pay \$10 million in Bitcoin within 24 hours, we will sign and release a malicious firmware update to all 2 million connected vehicles utilizing your TCUs, disabling their brakes at highway speeds."* Production has ground to a halt, and OEM clients are already calling about missed shipments.

6. Tabletop Exercise Questions

- 1) To pay or not to Pay (Safety vs Policy): Given the credible threat to human life (malicious firmware sent to cars), does the “No Ransom Payment” policy stand, or do we pay to prevent a potential mass-casualty event on the roads?
- 2) Disclosure and Panic: Do we immediately notify the OEM clients (Ford, GM) and the public that their cars might be vulnerable to remote attacks, risking mass panic and stock market crashes, or do we keep it quiet while we try to invalidate the stolen keys?